

SRA 472

Metlife AICPA Framework Project

Gavan Quimby

Jared Fetcho

Justin Griffiths

Executive Summary

Commented [GQ1]: No AI was used in the Executive Summary

Scope

This document provides a comprehensive overview of how MetLife adheres to the AICPA Framework for security policy compliance. It outlines our strategic approach to managing risks and implementing internal controls, ensuring robust data security and privacy measures are in place.

MetLife, Inc., established in 1868, is a leading global provider of insurance, annuities, and employee benefit programs, serving millions of customers across the world. With a rich history spanning over 150 years, MetLife has evolved into one of the largest and most respected financial services companies, dedicated to protecting families, supporting businesses, and fostering financial security. Headquartered in New York City, the company operates in nearly 50 countries, offering a wide range of products that include life insurance, dental and vision plans, accident and health insurance, and retirement solutions.

As a cornerstone of MetLife's mission, the commitment to maintaining the highest standards of security and compliance is critical, especially in an era where cybersecurity threats and regulatory demands are increasingly complex. In response to these challenges, MetLife has established a robust framework that aligns with the American Institute of Certified Public Accountants (AICPA) standards. This framework emphasizes the importance of security, confidentiality, and privacy across all aspects of our operations.

The purpose of this document is to provide a detailed overview of how MetLife complies with the AICPA Framework, focusing on key areas that ensure the integrity of our information systems and the protection of sensitive data. Through a combination of effective risk management, rigorous internal controls, and comprehensive employee training, we strive to uphold the trust placed in us by our customers, partners, and stakeholders.

Objectives

The primary objective of this document is to provide a clear overview of MetLife's compliance with the AICPA Framework, highlighting their dedication to security and operational excellence. Each segment of the framework is examined to demonstrate its alignment with industry best practices and regulatory standards.

MetLife aims to outline their approach to risk management, detailing how they identify and mitigate vulnerabilities, and to describe our internal controls that protect assets and ensure accurate reporting. The data security and privacy section will highlight the strategies for safeguarding sensitive information. Additionally, they will showcase our incident response management processes for effectively handling security incidents and our third-party management practices to ensure vendor compliance with their security standards.

The document will also address monitoring and auditing for ongoing assessment, regulatory requirements compliance, and the importance of employee training in fostering a security-aware culture. Lastly, we will illustrate our governance and accountability structures that support effective oversight of our security initiatives. Overall, this document strives to strengthen MetLife's commitment to maintaining security policies and enhancing stakeholder trust.

Stakeholders

Headquartered in New York, NY, MetLife and its affiliates offer a full range of insurance and other financial products and services. In addition to life, *non-medical health* and property and casualty insurance, MetLife is a leader in savings and retirement products and services for individuals, small businesses and large institutions. MetLife is the largest life insurer in terms of life insurance "in-force" in North America and offers financial products and services to over 96 of the top 100 FORTUNE 500® companies.¹

Metropolitan Life Insurance Company
200 Park Avenue
New York, New York 10166
USA
Tel: 1-800-MetLife

MetLife Acknowledges the following:

- American Life Insurance Company
- Economy Fire & Casualty Company
- Economy Premier Assurance Company
- Delaware American Life Insurance Company
- Economy Preferred Insurance Company
- Enterprise General Insurance Agency, Inc.
- Hyatt Legal Plans, Inc.

Commented [GQ2]: Referenced from MetLife's actual affiliates

Link: <https://www.metlife.com/about-us/corporate-profile/affiliates/>

Contents

Executive Summary2

 Scope2

 Objectives.....2

 Stakeholders3

Management Component.....5

Agreement, Notice, and Communication Component8

Collection and Creation Component11

Use, Retention, and Disposal Component14

Access Component17

Disclosure to Third Parties Component.....20

Security for Privacy Component23

Data Integrity and Quality27

Monitoring and Enforcement Component30

Management Component

1. Overview

The Privacy Management Component defines, documents, communicates and assigns responsibility and accountability for its personal information privacy policies and procedures. This section discusses the structure, framework, and roles that MetLife is structured under.

2. Privacy Governance Structure

To ensure accountability and oversight, MetLife has established a Privacy Governance Structure consisting of the following roles:

- **Chief Privacy Officer:** The Chief Privacy Officer is responsible for overseeing the development, implementation, and ongoing management of the privacy program. They report to the Board of Directors on privacy risks and compliance.
- **Privacy Committee:** A cross-functional group that supports the CPO in formulating privacy policies, reviewing privacy risks, and ensuring compliance across MetLife.
- **Privacy Managers:** Department-specific managers responsible for implementing privacy policies within their respective areas, ensuring that the department complies with privacy laws, and supporting data subject rights.
- **Data Protection Officer (DPO):** If required by law (such as GDPR), the DPO ensures that privacy practices are in line with legal requirements and helps MetLife monitor its compliance with data protection laws.

3. Privacy Policy Framework

- **Policy Documentation:** MetLife will have updated and stored co-personal information of the past iteration and changes that will change in MetLife's Framework.
- **Policy Approval:** All privacy policies must be approved by the Chief Privacy Officer and the Privacy Committee. They will be reviewed and updated annually to ensure they reflect changes in legal, regulatory, or operational requirements.
- **Policy Communication:** Privacy policies will be communicated across all levels of MetLife. This includes:

Commented [GQ3]: Typed out myself

Commented [GQ4]: Positions specifically redone, ChatGPT gave us positions specifically regarding the corporate side of MetLife. We have reformatted and redefined the positions to formally assigns responsibility.

Commented [GQ5]: Changed this to talk about keeping copies to safekeep older iterations of the framework.

AI originally talked about how its collected

Commented [GQ6]: Given to Chief Privacy Officer as their responsibility

- **Employee Training:** Annual mandatory privacy training sessions for employees to ensure awareness of privacy responsibilities. Must be approved of completion and compliant by the Data Protection Officer.
- **Internet Access:** Policies will be available on the company's internal internet for employees to read over. All policies and frameworks will be consented to by all MetLife Employees.
- **Vendor Communication:** Any Third-party vendor or partner will be provided with MetLife's privacy policies and asked to comply with them when handling personal if.

Commented [GQ7]: Made Employee Training Annual and must be verified that its completed by the data protection officer

Commented [GQ8]: Instead of Intranet, changed to the Internet Access for employees on a physical MetLife Location.

Commented [GQ9]: Kept from ChatGPT

4. Roles and Responsibilities

MetLife assigns the following key responsibilities to ensure privacy management is effectively executed:

Commented [GQ10]: AI gave the responsibilities but we physically went further in depth with what each role should do.

- **Chief Privacy Officer (CPO):**
 - Develop and maintain MetLife's privacy strategy and framework.
 - Will be responsible for updating the overall strategic plan every 5 years.
 - Ensure compliance with applicable privacy laws and regulations.
 - Following HIPPA guidelines when dealing with clients that have personal health information being stored.
 - Provide regular reports to senior leadership and the Board of Directors.
 - Will be done quarterly throughout the physical year.
 - Lead the response to any privacy incidents or breaches.
 - Will be responsible for assembling a team for privacy incidents.
- **Privacy Committee:**
 - Provide input and guidance on MetLife's privacy policies and initiatives.
 - Will have a vote in all privacy policy amendments.
 - Monitor the implementation of privacy programs and ensure they are functioning effectively.
 - Will have a project timeline submitted throughout each scrum.
 - Conduct periodic privacy audits and risk assessments.

- The Audits will be sent to company stakeholders to assure compliance.
- If there is deemed to be a breach a privacy manager should immediately notify the stakeholders of the breach or incident.

Commented [GQ11]: Refer to Stakeholders page.

Commented [GQ12]: If the breach involves private information requiring notification under legal standards), the IT worker ensures affected data subjects and regulatory authorities are informed promptly.

- **Privacy Managers:**

- Ensure that their departments follow the privacy policies and procedures.
 - Will report any issues to the CPO, CFO, and any other upper management.
- Handle requests from data subjects, including access and correction of privacy information.
 - Will be responsible for role-based access permissions for databases with personal client health information.
- Ensure privacy risks are identified and mitigated at the department level.
 - Mitigating physical privacy risks such as writing passwords, shoulder surfing, sharing flash drives, and more.

Commented [GQ13]: This is assuming the department is in a physical location and not remote working for MetLife

- **Employees:**

- Adhere to privacy policies and procedures when handling privacy information.
 - Will be required to sign NDA before disclosing information about clients.
- Report any suspected privacy incidents or breaches to the Privacy Manager or CPO.

5. Accountability and Reporting

- **Privacy Audits:** MetLife will conduct annual privacy audits to ensure compliance with privacy policies and procedures. Audits will assess the effectiveness of controls, identify privacy risks, and recommend improvements.
- **Incident Reporting:** Employees are required to immediately report any suspected privacy violations or breaches. The CPO will lead the investigation, and any incidents will be documented and tracked.
- **Performance Metrics:** Key performance indicators will be used to monitor privacy compliance, including:
 - Percentage of employees trained on privacy policies.

Commented [GQ14]: Audits changed to be done annually, and added indicators to monitor policy being followed.

- Number of privacy incidents reported.
- Compliance with data subject access requests.

6. Documentation and Record-Keeping Personal information

All privacy-related policies, procedures, and records (e.g., privacy risk assessments, training materials, incident reports) will be maintained in a centralized privacy repository. This will be accessible to the Privacy Committee and relevant stakeholders for review and audits.

7. Continuous Improvement

MetLife will continually evaluate and improve its privacy management practices:

- **Regular Review:** Policies and procedures will be reviewed annually to reflect changes in privacy laws, technology, and MetLife's operations.
- **Feedback Mechanism:** Employees and data subjects will be encouraged to provide feedback on privacy practices through surveys or other feedback mechanisms, which will be considered in future improvements.

Commented [GQ15]: Kept from AI

Agreement, Notice, and Communication Component

1. Overview

The Agreement, Notice, and Communication component ensures that MetLife transparently communicates its data collection, use, and protection practices to data subjects. It defines the processes for obtaining consent, notifying individuals about their rights and MetLife's data practices, and maintaining ongoing communication to keep them informed about any changes.

2. Key Principles

- **Transparency:** MetLife will clearly communicate why personal information is being collected, how it will be used, and with whom it may be shared.
- **Consent:** Explicit or implied consent will be obtained before collecting or processing personal information, and data subjects will be provided with options to accept or decline specific uses of their data.
- **Accessibility:** Notices and agreements will be written in clear, concise language and made available in accessible formats.

Commented [FJ16]: Typed general overview myself.

3. Consent Agreements

MetLife uses formal agreements to obtain data subject consent. These agreements include:

Commented [GQ17]: Added who is responsible for the consent agreements.

- **Terms of Service (ToS):** Clearly outlines MetLife's data practices, the rights of the data subjects, and MetLife's commitments to data protection.
 - The MetLife legal division will be responsible for monitoring TOS agreements. The Legal team currently at MetLife is Hyatt Legal Teams.
- **Consent Forms:** Separate consent forms are used for specific types of Privacy information collection, such as marketing communications, sensitive data processing, or third-party data sharing.
 - Consent Forms will also be monitored by Hyatt Legal Teams.
- **Opt-In/Opt-Out Mechanisms:** MetLife provides simple mechanisms for data subjects to opt into or out of data processing activities that are not essential to the service.
 - Will have a system to automatically send messages out opting into a service.

4. Privacy Notices

MetLife provides the following types of notices to ensure compliance and transparency:

- **Initial Notice:** At the time of data collection, data subjects are informed about:
 - What data is being collected.
 - Why it is being collected.
 - How it will be used.
 - How long it will be retained.
 - The data subject's rights.
- **Ongoing Notices:** Regular updates to privacy policies are communicated through email notifications, website banners, or mobile app alerts.
- **Incident Notices:** In case of a data breach or significant privacy-related incident, data subjects will be notified promptly, including details of the breach and recommended actions. (GDPR 72 hours more specific)

5. Communication Channels

MetLife uses a variety of channels to communicate privacy practices and updates:

- **Website Privacy Policy:** A publicly accessible, comprehensive document detailing MetLife's privacy practices, available on the company website.
 - Users will be prompted to accept cookies when on the MetLife webpage.

Commented [GQ18]: For sections 4-9 We try to focus in on some functionality of how MetLife is tracking consent from their clients. We also bring up how MetLife needs user consent on both the website and app.

Commented [FJ19]: This section highlights the different methods of direct communications for customers/clients.

- **Email Communication:** Regular updates and notifications are sent to data subjects about changes to privacy policies or new features impacting their data.
 - Users must opt in for email notifications.
- **Customer Support:** A dedicated privacy hotline and email address are available for data subjects to ask questions, request clarifications, or raise concerns.
 - **Current Support Number 1-877-638-2862**
- **Interactive Consent Interfaces:** Consent is obtained using digital tools such as checkboxes, toggles, or sliders on the MetLife website or app.
 - E-Signatures will be required for any contracts.

Commented [FJ20]: Actual MetLife Support Number

6. Data Subject Rights and Choices

MetLife ensures that data subjects are aware of their rights and provides mechanisms for exercising them:

- **Right to Information:** Data subjects can request details about the personal information MetLife collects and its intended uses.
- **Right to Withdraw Consent:** Data subjects can withdraw consent at any time via a simple opt-out mechanism.
- **Right to Object:** MetLife provides data subjects with the option to object to specific data uses, such as marketing or profiling.
- **Customizable Preferences:** Data subjects can manage their privacy preferences through an online portal or mobile app.

7. Documentation and Record-Keeping Personal information

To ensure accountability, MetLife maintains records of:

- **Consent Agreements:** Logs of when and how consent was obtained, including timestamps and method of agreement (e.g., electronic signature).
- **Notices Provided:** A history of privacy notices issued, and updates made, including versions and distribution dates.
- **Feedback and Queries:** Records of questions, complaints, or concerns raised by data subjects about privacy practices.

8. Training and Awareness

Employees who interact with data subjects are trained to:

Commented [FJ21]: Employee training is to be conducted annually or twice annually.

- Provide accurate and consistent information about privacy notices.
 - Will be done on the employee portal website.
- Assist data subjects with understanding and exercising their rights.
 - Will be given co-personal information of updated MetLife security policies.
- Respond promptly to privacy-related queries or complaints.

9. Continuous Improvement

MetLife regularly reviews its practices under this component by:

- **Periodic Review:** Privacy agreements, notices, and communication methods are reviewed annually to ensure compliance with evolving legal requirements and best practices.
- **Feedback Mechanisms:** Surveys and feedback forms are used to understand data subject satisfaction and make necessary adjustments to the communication approach.
- **Technology Updates:** Tools and platforms for obtaining and managing consent are updated to enhance user experience and ensure compliance

Commented [FJ22]: This can be taken from sources such as customer surveys or investor feedback.

10. Customer Referral Location

MetLife has the following hotline to for customers to reach out for any questions

Customer Service Hotline: 1-877-638-2862

- Will include an automated phone menu for users to be wired to the proper office
- Offices include HR, Finance, and Annuities.

Commented [GQ23]: MetLife's actual hotline

Collection and Creation Component

1. Overview

The Collection and Creation component of the Privacy Management Framework establishes guidelines for collecting and creating personal information in alignment with MetLife's privacy commitments. It ensures that private information is collected and created only for lawful, transparent, and explicitly stated purposes and is limited to what is necessary for achieving those purposes.

Commented [GQ24]: General Overview this component collects and creates PI only for the purposes identified in its agreements with data subjects,

2. Key Principles

- **Purpose Limitation:** Personal information will only be collected or created for specified, legitimate purposes that have been clearly communicated to data subjects.
- **Data Minimization:** Only the minimum amount of personal information necessary to fulfill the stated purpose will be collected or created.
- **Fair and Lawful Collection:** Personal info will be collected in compliance with applicable laws, and data subjects will be informed of the purpose and legal basis for collection.
- **Accuracy and Relevance:** All personal information collected and created must be accurate, relevant, and kept up to date for its intended use.

3. Data Collection Processes

MetLife uses the following methods for collecting personal information:

1. **Direct Collection:** Personal information is collected directly from data subjects through methods such as:
 - Online forms that are monitored by the Data Privacy Officer (registration, subscription, feedback forms).
 - Mobile app data input will be monitored by the Chief Privacy Officer.
 - Verbal interactions (customer support calls or in-person interactions).
2. **Automated Collection:** Personal information is collected automatically through systems or devices, such as:
 - Cookies and website analytics tools. The user **MUST** consent to using Cookies.
 - IoT devices or mobile applications.
 - System logs and transaction records. Users will also be informed that they are being used to collect data when logging into their MetLife Account.
3. **Third-Party Collection:** Personal information is obtained from trusted third-party sources under formal agreements ensuring compliance with MetLife's privacy standards.

4. Data Creation Processes

In some cases, MetLife generates or derives new personal information through processing or analysis. Examples include:

- **Derived Data:** Creating user profiles or behavioral patterns based on collected data.
- **Aggregated Data:** Combining data sets to identify trends or insights without identifying individual data subjects.

Commented [GQ25]: Discussing how Personal Information is being collected.

ChatGPT originally gave us definitions on how to collect said information.

- **Generated Data:** Data created by MetLife, such as internal reference numbers or anonymized identifiers.

Commented [FJ26]: For example, patient ID numbers.

5. Data Collection Transparency

- **Notice to Data Subjects:** At the point of collection, data subjects will be informed of:
 - The specific personal information being collected.
 - The purpose for which it is being collected.
 - The legal basis for collection.
 - How it will be used and with whom it may be shared.
- **Consent Mechanisms:** Where applicable, consent will be obtained before data collection. For automated data collection, MetLife will provide clear opt-in or opt-out options.
 - **Opt-in mechanisms will be shown up front with documentation leading into this privacy policy on why the security branch is collecting the data.**

Commented [GQ27]: This was added to be the most transparent part of the document.

Users consent **MUST** be obtained whether via opt in or opt out mechanisms.

6. Data Collection Safeguards

- **Security Controls:** Systems collecting or storing personal information are equipped with encryption, access controls, and other security measures to prevent unauthorized access.
- **Quality Assurance:** Automated systems for data collection undergo regular testing to ensure data accuracy and consistency.
- **Vendor Oversight:** When third-party vendors collect data on MetLife's behalf, formal agreements ensure compliance with MetLife's privacy standards.

Commented [GQ28]: Sections 6-9 were changed to describe how MetLife plans to protect, monitor, and document personal information.

7. Documentation and Record-Keep Personal information

To ensure accountability, MetLife maintains detailed records of:

- **Data Inventory:** A centralized log of all personal information collected, including data type, source, purpose, and retention period.
- **Collection Methods:** Documentation of the methods used for collection, including system and process details.
- **Consent Records:** Proof of consent obtained for personal information collection, including timestamps and method of agreement.

8. Data Subject Rights

Commented [FJ29]: Such rights and practices would provide more transparency and would give subjects more control over their data.

- **Access Requests:** Data subjects can request a copy of the personal information MetLife has collected about them.
- **Correction Requests:** Data subjects can request corrections to inaccurate or incomplete Personal information,
- **Data Collection Inquiries:** Data subjects can inquire about the purpose and scope of personal information collection and receive prompt, transparent responses.

9. Monitoring and Continuous Improvement

MetLife ensures compliance and refinement of collection and creation processes through:

- **Regular Audits:** Periodic assessments of data collection methods to ensure they align with stated purposes and applicable laws.
- **Feedback Mechanisms:** Soliciting feedback from data subjects on their experience with data collection processes.
- **Process Optimization:** Updating systems and processes based on audit findings, technological advancements, or changes in legal requirements.

Commented [FJ30]: To be conducted by a governmental agent or other authorized officer

Use, Retention, and Disposal Component

1. Overview

The Use, Retention, and Disposal component ensures that personal information is used solely for its intended and communicated purposes, retained only for as long as necessary, and securely disposed of once it is no longer required. This framework aligns with MetLife's commitment to purpose limitation, legal compliance, and the protection of data subjects' rights.

Commented [GQ31]: This component discusses the limits the of the use of personal information to the purposes identified in its objectives related to privacy.

2. Key Principles

- **Purpose Limitation:** Personal information will only be used for the purposes explicitly communicated to and agreed upon by the data subjects.
 - Data subjects would be prompted with the consent form as previously stated in the Collection Creation is Disposal component.
- **Retention Minimization:** Personal information will be retained only as long as necessary to fulfill its intended purposes or comply with legal, regulatory, or contractual obligations.
- **Secure Disposal:** Once retention is no longer required, personal information will be securely and irreversibly deleted or destroyed to prevent unauthorized access or recovery.

3. Use of Personal information

MetLife ensures to:

- **Adhere to Purpose:** Use personal information only for the purposes communicated in privacy notices or consent agreements.
- **Restrict Access:** Limit access to personal information to authorized personnel based on a need-to-know basis and role-specific permissions.
- **Prohibit Unauthorized Uses:** Prevent the use of personal information for secondary purposes without obtaining additional consent from the data subject, unless legally permitted.
- **Implement Logging and Monitoring:** Track access to personal information to ensure it is used appropriately and detect potential misuse.

4. Retention of Personal information

MetLife maintains a robust data retention policy:

- **Retention Periods:**
 - Define and document retention periods for each category of personal information based on its purpose, regulatory requirements, and business needs.
 - **Examples:**
 - Customer account information: Retained for the duration of the account plus one year for regulatory compliance.
 - Insurance data: Retained for seven years to comply with financial and tax regulations (IRS).
 - Job applicant data: Retained for six months post-hiring decision unless the applicant consents to a longer period.

Commented [GQ32]: Examples were created to talk about the longevity of specific insurance information.

- **Regular Reviews:**
 - Conduct periodic reviews of stored personal information to ensure retention aligns with documented policies.
 - Archive or delete personal data that no longer serves its purpose.
 - **Retention Exemptions:** Identify and document situations where longer retention is required (e.g., legal hold or active litigation).
-

5. Disposal of Personal information

MetLife ensures the secure and irreversible disposal of personal information:

- **Secure Deletion:** Digital records are deleted using methods that prevent recovery, such as overwriting or cryptographic erasure.
 - **Physical Disposal:** Physical records containing personal identifiers are shredded, incinerated, or disposed of using certified third-party destruction services.
 - **Disposal Logs:** Maintain detailed logs of data disposal activities, including the date, method, and personnel involved.
-

6. Compliance with Legal and Regulatory Requirements

MetLife ensures retention and disposal practices comply with:

- Applicable data protection laws (e.g., GDPR, CCPA, or local regulations).
 - Industry-specific standards (e.g., HIPAA for healthcare data, PCI DSS for payment data).
-

7. Data Subject Rights

MetLife respects data subject rights during the use, retention, and disposal stages:

- **Access and Portability:** Provide data subjects with access to their personal information and allow them to request a copy of their data in a portable format.
 - **Correction:** Allow data subjects to request corrections to their personal information while it is retained.
 - **Erasure (Right to be Forgotten):** Honor requests for the deletion of personal information unless retention is required by law or legitimate business needs.
-

8. Safeguards for Retained Data

To protect personal information during retention, MetLife implements:

- **Encryption:** Retained data is encrypted both in transit and at rest.
- **Access Controls:** Access to retained data is restricted to authorized personnel.
- **Regular Audits:** Periodic audits of retained data to ensure compliance with retention policies and detect security vulnerabilities.

9. Monitoring and Continuous Improvement

MetLife continuously refines its practices for using, retaining, and disposing of personal information:

- **Regular Policy Updates:** Retention and disposal policies are reviewed annually or in response to changes in legal or regulatory requirements.
- **Employee Training:** Train employees on proper use, retention, and disposal practices.
- **Feedback Mechanisms:** Gather insights from audits, incidents, and stakeholder feedback to improve processes.

Access Component

1. Overview

The Access component ensures that data subjects can exercise their rights to access, review, and update their personal information held by MetLife. It establishes clear processes for handling access requests, correcting data inaccuracies, and addressing privacy concerns while safeguarding personal information against unauthorized access.

2. Key Principles

- **Transparency:** Data subjects are informed about their rights to access, review, and update their personal information and how to exercise these rights.
- **Ease of Access:** MetLife provides straightforward mechanisms for data subjects to request and obtain access to their personal information.
- **Accuracy:** Data subjects can request corrections to inaccuracies or errors in their personal information to maintain its relevance and validity.
- **Security:** Access requests are verified and processed securely to prevent unauthorized disclosure or misuse of personal information.

Commented [GQ33]: Kept the definitions from AI as it clearly lays out access to an individuals personal information.

3. Data Subject Rights Under the Access Component

- **Right to Access:** Data subjects can request to know what personal information MetLife holds about them, how it is used, and with whom it is shared.
- **Right to Correction:** Data subjects can request corrections to inaccurate or incomplete personal information.
- **Right to Explanation:** MetLife provides explanations for how decisions involving personal information are made, especially in automated processing.
- **Right to Restrictions:** Data subjects can request the restriction of processing while disputes about data accuracy or usage are resolved.

4. Access Request Process

1. Submission of Requests:

- Data subjects can submit access requests through:
 - Online forms on MetLife's website.
 - Email or postal mail using dedicated contact details.
 - Customer service hotline: MetLife - 1-877-638-2862

Commented [GQ34]: MetLife's real hotline

2. Verification of Identity:

- Before fulfilling requests, MetLife verifies the identity of the data subject through secure methods, such as:
 - Government-issued ID verification.
 - Multi-factor authentication for online accounts.

3. Processing Requests:

- Access requests are processed within a defined timeframe (e.g., 30 days) in accordance with applicable legal requirements.
- Acknowledgment of the request is provided upon receipt, including a reference number and estimated timeline for resolution.

4. Fulfillment of Requests:

- Data subjects receive:
 - A copy of their personal information in a structured, commonly used format.
 - Information about how the personal information is being used and the categories of third parties with whom it is shared.
- For correction requests, MetLife updates inaccurate data promptly and notifies the data subject once the correction is completed.

5. Denial of Requests:

- If a request cannot be fulfilled due to legal or technical constraints, the data subject is provided with a clear explanation and information about their right to appeal or lodge a complaint.

5. Internal Controls and Safeguards

- **Role-Based Access:** Access to personal information within MetLife is granted on a need-to-know basis to authorized personnel only.
- **Audit Trails:** All access to and modifications of personal information are logged and monitored for unauthorized activity.
- **Data Minimization:** Data provided during access requests is limited to the requested scope to prevent over-disclosure.

6. Communication of Access Rights

- **Privacy Policy:** MetLife's privacy policy includes a detailed explanation of access rights and how to exercise them.
- **Educational Materials:** Tutorials, FAQs, and contact resources are available to help data subjects understand the process for accessing their personal information.

7. Handling Data Disputes and Complaints

- **Dispute Resolution:** MetLife has procedures in place to resolve disputes about data accuracy or access within a defined timeframe.

- **Complaint Escalation:** If data subjects are dissatisfied with the resolution, they are provided options to escalate complaints to supervisory authorities or independent review bodies.

8. Monitoring and Continuous Improvement

- **Performance Metrics:** MetLife tracks metrics such as the number of access requests, average processing time, and satisfaction ratings to improve access processes.
 - **Regular Audits:** Periodic reviews ensure compliance with access-related policies and identify areas for improvement.
 - **Feedback Mechanisms:** Data subjects are encouraged to provide feedback on their experience with the access request process.
-

9. Employee Training

- Employees handling access requests receive training on:
 - Data subject rights and organizational policies.
 - Secure processing of access and correction requests.
 - Providing clear and helpful communication to data subjects.

Disclosure to Third Parties Component

1. Overview

The Disclosure to Third Parties component outlines the principles, practices, and safeguards for sharing personal information with third parties. This section ensures that personal information is disclosed only for legitimate, transparent, and consented purposes while maintaining compliance with applicable privacy regulations and contractual obligations.

2. Key Principles

- **Purpose Limitation:** MetLife will be disclosing to third parties only for purposes explicitly communicated to and agreed upon **by data subjects (clients)**.
- **Consent-Driven:** Data subjects provide explicit (or implied, where appropriate) consent before their personal information is shared, except where disclosure is required by law. Consent can also be agreed to by online e-signatures, and other appropriate forms.
 - **Refer to Agreement Notice and Communication Component for more information.**

Commented [GQ35]: Discussing consent for outsourcing with third parties.

Commented [GQ36]: Specifically Consented to by the Clients.

Commented [GQ37]: This was discussed in a previous component

- **Contractual Controls:** Any consented agreements with third party vendors will enforce privacy and security obligations consistent with MetLife's standards.
- **Transparency:** Data subjects are informed about the categories of third parties with whom their personal information may be shared.

3. Types of Third-Party Disclosures

1. **Service Providers:** Personal information is shared with vendors or contractors providing services such as payment processing, IT support, or marketing.
2. **Legal and Regulatory:** Personal information is disclosed to authorities such as CPO, Hyatt Legal Team, or any other regulatory body as required to comply with legal obligations or investigations.
3. **Business Partners:** Personal information is shared with trusted partners for co-branded services or joint marketing efforts, with explicit consent from data subjects.
 - Will work closely with the Strategic Communications Office.
4. **Emergency Situations:** Personal information may be disclosed without consent to protect the vital interests of data subjects, such as during a health or safety emergency.

Commented [GQ38]: Hyatt Legal Team is actually third party but Metlife uses them as their main legal team.

4. Data Subject Consent

MetLife ensures that data subjects provide informed consent for third-party disclosures:

- **Explicit Consent:** Obtained for sensitive personal information or when sharing data with business partners for marketing purposes.
- **Opt-In/Opt-Out Mechanisms:** Provided for non-essential disclosures, allowing data subjects to choose their preferences.
- **Withdrawal of Consent:** Data subjects can withdraw consent for future third-party disclosures through accessible mechanisms such as online account settings or written requests.
 - **For more information regarding customer consent please refer to Access and Collection Components.**

5. Transparency and Notices

Data subjects are informed about third-party disclosures through:

- **Privacy Policy:** Refer to Access component. Users will have the ability to read through MetLife's privacy policies.

- **Consent Agreements:** Specify the nature of personal information shared, the purpose, and the third parties involved.
- **Ongoing Updates:** Notify data subjects of any significant changes in third-party relationships or practices.
 - **Users must consent for more ongoing updates.**

Commented [GQ39]: Consent can be either physical, verbal, or done on an electronic.

6. Safeguards for Third-Party Disclosures

- **Due Diligence:** Conduct privacy and security assessments of third parties before entering agreements.
- **Contractual Obligations:** Ensure contracts include provisions requiring third parties to:
 - Use personal information only for specified purposes.
 - Implement appropriate security measures to protect personal information.
 - Notify MetLife of any breaches or non-compliance.
- **Regular Audits:** Periodically review third-party compliance with privacy obligations.

Commented [GQ40]: Privacy assessments will be done by a selection of different branches to determine if a third party vendor is appropriate.

7. Exceptions to Consent Requirements

personal information may be disclosed without consent under specific circumstances, such as:

- **Legal Requirements:** Compliance with subpoenas, court orders, or other legal obligations.
- **Public Interest:** Disclosure for public safety, fraud prevention, or other vital societal purposes.

In such cases, MetLife ensures:

- **Minimization:** Only the necessary personal information is disclosed.
- **Notification:** Data subjects are informed, where legally permissible, about the disclosure.

8. Monitoring and Oversight

MetLife monitors third-party disclosures to ensure compliance and minimize risks:

- **Disclosure Logs:** MetLife monitors detailed records of personal information disclosures, including personal information, purpose, and date.
- **Incident Management:** Investigate and address any unauthorized or improper disclosures promptly.

- **Third-Party Risk Assessments:** Regularly evaluate the privacy and security practices of third-party partners.

9. Data Subject Rights and Disclosures

- **Access Requests:** Data subjects can request a list of third parties with whom their personal information has been shared.
- **Objection to Disclosures:** Data subjects can object to specific third-party disclosures, except where required by law.
- **Request for Erasure:** personal information disclosed to third parties is erased upon request, where feasible and compliant with legal requirements.

10. Employee Training and Awareness

Employees involved in third-party disclosures are trained on:

- Privacy and confidentiality obligations.
- Identifying unauthorized or improper disclosures.
- Handling data subject queries or concerns about third-party sharing.

Commented [GQ41]: This refers to legal and privacy officer positions.

11. Continuous Improvement

MetLife refines its practices for third-party disclosures through:

- **Feedback Mechanisms:** Collecting insights from data subjects, audits, and incidents to improve processes.
- **Technology Updates:** Adopting tools for automated tracking and management of third-party disclosures.
- **Policy Reviews:** Regularly updating disclosure policies to align with evolving legal requirements and industry standards.

Security for Privacy Component

1. Overview

The Security for Privacy component establishes robust practices to protect personal information from unauthorized access, alteration, removal, destruction, or disclosure. This section focuses on safeguarding both physical and digital assets, ensuring compliance with privacy regulations, and fostering trust with data subjects through proactive risk management and breach prevention.

Commented [GQ42]: This section will list examples and procedures for how MetLife measures that personal information is being protected.

2. Key Principles

- **Confidentiality:** Personal information is accessible only to authorized individuals and processes. Authorized individuals may be given role-based access.
- **Integrity:** Personal information is protected from unauthorized modifications or corruption.
- **Availability:** Personal information is accessible to authorized users when needed.
- **Accountability:** MetLife enforces security measures and tracks compliance through regular audits and reporting.

Commented [GQ43]: Introduction of Role Based Access in the Privacy Document.

Commented [GQ44]: Available on the user on web client or shared Metlife Database.

3. Security Governance

- **Policies and Procedures:** Employees from the IT branch are aligned with privacy requirements, including data classification, access control, and incident response.
- **Roles and Responsibilities:** Assign accountability for security measures to designated personnel or teams, such as a Chief Information Security Officer (CISO).
- **Compliance Monitoring:** Ensure adherence to regulatory and contractual obligations related to data security.

Commented [GQ45]: Specific branch for more clarity.

4. Technical Safeguards

1. Access Controls:

- **Role-Based Access:** Restrict personal information access to personnel based on their job responsibilities.
- **Authentication Mechanisms:** MetLife has multi-factor authentication (MFA) specifically for employees when they're accessing sensitive systems.
- **Session Management:** Use automatic session timeouts to reduce exposure risks.

Commented [GQ46]: Refer to Management section for deeper insight on roles.

Commented [GQ47]: Designed for employees MFA not Client

2. Encryption:

- **In Transit:** Encrypt data transmissions using secure protocols such as TLS.
- **At Rest:** Encrypt stored personal information using industry-standard algorithms like AES-256.

Commented [GQ48]: Transport Layer Security Encryption

Commented [GQ49]: Referencing a different encryption standard.

3. Network Security:

- MetLife's Network security will use firewalls, intrusion detection/prevention systems (IDS/IPS), and virtual private networks (VPNs) to secure organizational networks.
- Segment networks to limit exposure in the event of a breach.

4. Data Minimization:

- Retain only the minimum personal information necessary for legitimate purposes.
- Mask or tokenize data where applicable.
- Refer to Retention component.

5. Physical Safeguards

- **Secure Facilities:** Restrict access to data centers and offices with personal information storage using access badges, biometric systems, or security personnel.
- **Media Protection:** Secure devices and storage media containing personal information through encryption and physical locks.
- **Disposal Protocols:** Shred physical documents and use certified destruction services for hardware and storage devices.

6. Organizational Safeguards

1. Employee Training:

- Conduct regular security awareness training to educate employees about privacy risks, phishing attacks, and secure data handling.
- Provide specialized training for IT and data privacy teams.

Commented [GQ50]: Specialized instructions for IT workers.

2. Third-Party Security:

- Require vendors and contractors to adhere to security standards through contracts and regular assessments.
- Verify third-party compliance with periodic security audits.

7. Incident Response and Breach Management

- **Incident Response Plan:** Chief Privacy Officer is responsible for a documented plan detailing steps for identifying, containing, and mitigating security incidents.
 - Steps include identifying compromised systems, securing unauthorized access points, and logging all activities during the investigation.
 - Once logged immediately report to the CPO.
- **Breach Notification:** Notify affected data subjects, regulators, and other stakeholders promptly in accordance with applicable legal requirements.

Commented [GQ51]: The IT worker reviews the organization's incident response plan, outlined here to isolate and mitigate the breach.

Commented [GQ52]: Given responsibility to the CPO

- **Root Cause Analysis:** Investigate breaches to identify root causes and implement corrective actions to prevent recurrence.
-

8. Data Subject Rights and Security

- Ensure that measures to secure personal information do not hinder data subjects' ability to exercise their rights, such as accessing or correcting their data.
 - Provide secure channels for data subjects to submit access, correction, or deletion requests.
 - This channel will act as an "Opt Out" feature for consent and will need to regain consent from previously mentioned consent agreements.
-

Commented [GQ53]: This is how a client would Opt Out from any consented agreements.

9. Risk Management and Continuous Improvement

1. Risk Assessments:

- Perform regular risk assessments to identify potential threats to personal information security.
- Update mitigation strategies based on assessment results.

2. Testing:

- Conduct penetration testing and simulated phishing campaigns to evaluate security resilience.
- Test backup and recovery systems to ensure data availability.

3. Policy Reviews:

- Review and update security policies annually or after significant incidents.
-

10. Compliance and Reporting

- Align with relevant security standards and regulations, such as ISO/IEC 27001, NIST Cybersecurity Framework, GDPR, and CCPA.
 - Maintain logs of security measures and incidents to demonstrate compliance during audits or legal reviews.
-

Data Integrity and Quality

1. Overview

The Data Integrity and Quality component focuses on maintaining accurate, complete, and relevant personal information throughout its lifecycle. This component ensures that personal information collected, stored, and used by MetLife meets high-quality standards, supports decision-making, and aligns with the purposes identified in agreements and notices provided to data subjects.

Commented [GQ54]: Overviews how data remains accurate in MetLife's Database.

2. Key Principles

- **Accuracy:** Personal information must be correct, precise, and free of errors.
- **Completeness:** Personal information should include all necessary elements to fulfill its intended purpose.
- **Relevance:** Personal information must be pertinent to the specified purposes and not excessive.
- **Timeliness:** Personal information must be kept up-to-date and refreshed periodically to avoid obsolescence.

3. Data Integrity Controls

1. Validation Mechanisms:

- Validate personal information at the point of collection using tools such as form field validation, duplicate checks, and automated consistency checks.
- Cross-reference personal information with authoritative sources when appropriate.

2. Ongoing Quality Assurance:

- MetLife will schedule **WEEKLY** reviews of personal information to verify accuracy and completeness.
- Utilize data profiling tools to detect anomalies, duplicates, or missing values.

Commented [GQ55]: This is the time frame for how MetLife updates their data.

3. Error Correction Processes:

- Establish procedures for identifying and correcting errors in personal information.
- Allow data subjects to request corrections through accessible channels, such as self-service portals or customer service teams.

4. Data Lifecycle Management

- **Collection:** Ensure personal information is collected in alignment with stated purposes and with mechanisms to verify data quality at the source.
- **Storage:** Maintain data in structured formats to simplify quality checks and facilitate corrections.
- **Usage:** Monitor for signs of inaccurate or incomplete data during processing activities.
- **Archiving and Disposal:** Periodically review archived data for relevance and dispose of outdated or irrelevant data securely.

5. Communication with Data Subjects

- **Notification of Errors:** Notify data subjects promptly if errors in their personal information are discovered and require their input for correction.
- **Request Handling:** Facilitate data subject requests for reviewing and correcting their personal information through transparent and efficient processes.
- **Educational Materials:** Provide guidance to data subjects on how to provide accurate data to reduce errors at the source.
 - Clients can refer to <https://www.metlife.com/insurance/life-insurance/beneficiary-assistance/> for more information.

Commented [GQ56]: This is key for incident response management.

Commented [GQ57]: Provides users with how to contact assistance and other informative tools with giving personal data.

6. Employee Training and Awareness

- Educate employees on the importance of data integrity and quality, including:
 - Methods for identifying and reporting data quality issues.
 - Techniques for validating data at the point of entry or collection.
- Provide specialized training for data management teams on data profiling, cleansing, and validation tools.

Commented [GQ58]: This refers to Human Resources and IT offices.

7. Tools and Technology for Data Quality

1. **Data Profiling Tools:** Analyze datasets for completeness, accuracy, and consistency.
2. **Master Data Management (MDM) Systems:** Centralize and standardize data to ensure a single source of truth.
3. **Automated Validation:** Use AI or rules-based systems to flag potential inaccuracies or inconsistencies.

4. **Audit Logs:** Maintain records of data updates and corrections for accountability and monitoring.
-

8. Monitoring and Continuous Improvement

1. **Performance Metrics:** Track metrics such as error rates, correction times, and the frequency of data refreshing.
 2. **Data Quality Audits:** Conduct regular audits of datasets to identify and address integrity issues.
 3. **Feedback Mechanisms:** Encourage data subjects and employees to report discrepancies or concerns about data quality.
-

9. Regulatory and Compliance Alignment

- Align data quality practices with relevant standards and regulations, such as GDPR (Article 5 - Data Accuracy) and CCPA requirements for accurate personal information.
 - Maintain compliance documentation to demonstrate adherence during audits or legal reviews.
-

10. Incident Management

- **Error Identification:** Establish protocols for identifying data integrity issues, such as system errors or unauthorized modifications.
 - **Correction and Remediation:** Respond to incidents with appropriate corrective measures, including root cause analysis and updating affected systems or processes.
 - **Notification:** Inform affected data subjects and relevant stakeholders about incidents involving data integrity, when required.
-

11. Governance and Oversight

- Appoint data stewards or integrity managers to oversee data quality initiatives.
- Establish a data governance committee to define data quality standards, monitor compliance, and approve improvement strategies.

Monitoring and Enforcement Component

1. Overview

The Monitoring and Enforcement component ensures compliance with privacy policies and procedures by establishing oversight mechanisms, proactive monitoring, and responsive enforcement actions. This component includes measures for handling privacy-related complaints and disputes while fostering accountability and continuous improvement.

Commented [GQ59]: This last section talks about monitoring policies and communicating findings back to the organization and other clients.

2. Key Principles

- **Compliance Assurance:** Regularly monitor and assess adherence to privacy policies and legal obligations.
- **Accountability:** Hold individuals and teams responsible for maintaining compliance.
- **Transparency:** Clearly communicate monitoring practices and enforcement procedures to stakeholders, including data subjects.
- **Dispute Resolution:** Provide efficient mechanisms for addressing privacy-related complaints and disputes.

3. Monitoring Practices

1. Internal Audits:

- Conduct periodic audits of data handling practices to ensure compliance with privacy policies. These audits will be done monthly.
- Privacy Managers are responsible for reviewing access logs, data sharing activities, and adherence to data minimization principles.

2. Automated Monitoring:

- Deploy tools for continuous monitoring of data usage, access, and sharing activities.
- Use alerts for unusual or unauthorized activities, such as excessive data access or unexpected exports.

3. Third-Party Oversight:

- Monitor vendor and partner compliance with contractual privacy obligations through regular reviews and audits.
- Require third-party reporting on their privacy compliance activities.
- Refer to Third Party Component for More Information.

4. Compliance Metrics:

- Track key performance indicators, such as policy adherence rates, incident response times, and complaint resolution rates.

4. Complaint and Dispute Handling**1. Complaint Channels:**

- Provide accessible channels for data subjects to file privacy-related complaints, such as online forms, email, or customer service hotlines.
- Ensure channels are available in multiple languages, where applicable.

2. Investigation Procedures:

- Acknowledge receipt of complaints within a specified timeframe.
- Assign investigations to designated privacy officers or committees.
- Maintain impartiality and confidentiality throughout the process.

3. Resolution Mechanisms:

- Offer tiered resolution processes, including direct remediation, mediation, or escalation to regulatory bodies if necessary.
- Communicate outcomes clearly to data subjects and provide further options for unresolved disputes.

5. Enforcement Procedures**1. Policy Violations:**

- Consult with Hyatt Legal and higher ranked positions regarding consequences for non-compliance with privacy policies, ranging from retraining to disciplinary actions.
- Document and enforce corrective measures to address policy violations.

2. Incident Response:

- Investigate suspected breaches of privacy policies or unauthorized activities.
- Report incidents to affected parties and regulatory bodies as required.
- Implement root cause analysis and update policies to prevent recurrence.

3. Contractual Enforcement:

Commented [GQ60]: The IT worker consults this section to investigate the source of the breach (e.g., whether it stemmed from internal errors or external attacks).

- Enforce privacy requirements with third parties, including penalties or termination for non-compliance.

6. Governance and Accountability

1. Privacy Oversight Committees:

- MetLife will establish committees to oversee privacy compliance, monitor enforcement actions, and recommend policy updates.
- Include representatives from legal, IT, compliance, and data privacy teams.

2. Reporting Structures:

- Require regular reporting of privacy monitoring activities and enforcement outcomes to executive leadership.
- Share summaries of monitoring and enforcement activities in public-facing transparency reports.

7. Training and Awareness

- Train employees on their roles in monitoring and enforcement, including identifying and reporting potential violations.
- Conduct periodic refresher sessions on privacy policies and enforcement mechanisms.

8. Continuous Improvement

1. Feedback Mechanisms:

- Solicit feedback from data subjects, employees, and regulators to identify areas for improvement.
- Use insights from complaints, disputes, and audits to refine policies and procedures.

2. Policy Reviews:

- Regularly review and update privacy policies to reflect changes in legal requirements, business practices, or risk assessments.
- Ensure enforcement procedures remain effective and fair.

3. Technology Upgrades:

- Invest in advanced monitoring tools to improve detection and enforcement capabilities.

Commented [GQ61]: An IT worker would go here to future proof.

9. Transparency and Accountability to Data Subjects

- **Privacy Statements:** Include descriptions of monitoring and enforcement practices in privacy notices.
- **Complaint Updates:** Clients will be informed about the status and outcomes of their complaints or disputes.
- **Incident Reports:** There will be an automated service that will share information about significant enforcement actions or breach responses, ensuring accountability.

10. Compliance with Legal Standards

- Align monitoring and enforcement practices with relevant legal frameworks, such as GDPR (Article 33 & 58), CCPA, and other privacy laws.
- Maintain detailed records to demonstrate compliance during audits or legal inquiries.

References

<https://www.metlife.com/support-and-manage/contact-us/>

<https://www.metlife.com/support-and-manage/contact-us/contacts-for-individual/#identityprotection>

ChatGPT 4.0